

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 18

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM5-028)

Which statement BEST describes inherent risk?

- A. The risk formally retained by an authorized owner
- B. The desired exposure after planned treatment
- C. The risk remaining after current controls
- D. The exposure before considering the effect of controls

Question 2 (CISM5-029)

What is the PRIMARY purpose of risk tolerance?

- A. To calculate every loss in currency
- B. To define acceptable variation or limits for a particular objective or exposure
- C. To describe maximum organizational capacity
- D. To assign control operation to security

Question 3 (CISM5-030)

Scenario: A tax-preparation service tolerates eight hours of portal downtime off-season but only 20 minutes during the filing deadline. Its annual assessment uses the off-season limit.

What should the information security manager do FIRST?

- A. Reassess the deadline scenario using the 20-minute tolerance and related business impact
- B. Keep one limit to preserve consistency
- C. Use the infrastructure team's preferred target
- D. Wait for a deadline outage

Question 4 (CISM5-031)

Scenario: A cold-storage company rates a sensor gateway as low criticality because it stores no customer data. Without it, temperature alerts stop and perishable inventory may be lost before staff detect a failure.

Which conclusion is MOST appropriate?

- A. The gateway remains low because confidentiality is minimal
- B. Only the sensor hardware requires assessment
- C. Availability criticality should reflect inventory-loss and detection dependencies
- D. Every gateway is automatically mission critical

Question 5 (CISM5-032)

Scenario: A design firm adopts cloud file storage. The provider protects infrastructure, while the firm must configure sharing and retention. The project assumes the provider handles both tasks.

What is the PRIMARY risk finding?

- A. Cloud storage always increases inherent risk
- B. Provider certification resolves configuration risk
- C. The provider now owns the firm's design risk
- D. Customer-side controls may be unowned and ineffective

Question 6 (CISM5-033)

Scenario: A warehouse will use autonomous vehicles managed by a vendor platform. The pilot evaluates productivity but not command integrity, update support, safety impact, or vendor-service failure.

What is the MOST significant assessment gap?

- A. Safety, malicious-command, lifecycle, and supplier-dependency scenarios were omitted
- B. Productivity was measured before full deployment
- C. The pilot did not compare paint colors
- D. Vehicle purchase price was not benchmarked

Question 7 (CISM5-034)

When is a structured qualitative assessment MOST appropriate?

- A. When technical scores must be converted directly to dollars
- B. When an exact annual loss forecast is mandatory
- C. When expert judgment must support initial prioritization and reliable numerical data is limited
- D. When business impact is irrelevant

Question 8 (CISM5-035)

Scenario: A media archive is valued at \$900,000. A loss event would affect 20% of its value and is expected 0.25 times per year.

What is the annualized loss expectancy?

- A. \$22,500
- B. \$180,000
- C. \$225,000
- D. \$45,000

Question 9 (CISM5-036)

Scenario: A university requires weekly review of privileged activity. Reviews occur on schedule, but the report excludes cloud administrators because the procedure never included them.

What is the PRIMARY issue?

- A. An operating deficiency because reviews occur weekly
- B. An incomplete control design
- C. A threat event
- D. A realized loss

Question 10 (CISM5-037)

Scenario: A retailer reports low residual risk because a monitoring control is funded for next quarter. Current controls leave exposure above tolerance.

How should the register be corrected?

- A. Count funded controls as fully effective
- B. Report current residual risk and record the verified target separately
- C. Reduce inherent risk
- D. Remove the scenario until deployment

Question 11 (CISM5-038)

Scenario: Three regional banks use different statement vendors, but all vendors rely on one document-rendering service with no alternate provider.

Which exposure should be highlighted?

- A. A shared fourth-party failure could disrupt all three services simultaneously
- B. Different statement designs
- C. Every vendor must receive an identical rating
- D. The banks have transferred all accountability

Question 12 (CISM5-039)

Scenario: Two risks have equal scores. One may interrupt online donations during a campaign starting tomorrow; the other affects an archive with a tested manual workaround and no deadline.

Which should be prioritized?

- A. The archive because it is older
- B. The donation service because its campaign impact is imminent
- C. Whichever has more findings
- D. Neither because scores match

Question 13 (CISM5-040)

Scenario: A loss model based on limited data produces a broad range, but management requests one guaranteed value.

What should the information security manager provide?

- A. The maximum value labeled as expected loss
- B. A technical score converted to currency
- C. No analysis at all
- D. A range or distribution with assumptions and sensitivity information

Question 14 (CISM5-041)

Scenario: A logistics firm rates database-recovery risk low because file restores are tested monthly. The assessed scenario concerns a clustered database never included in testing.

What is the BEST conclusion?

- A. Residual risk may be understated by irrelevant control evidence
- B. Test frequency proves effectiveness
- C. Inherent risk is reduced
- D. The rating should be accepted without review

Question 15 (CISM5-042)

Scenario: A transit board must fund resilience for its fare platform. It receives hundreds of technical findings but no service-impact scenario or response comparison.

What should be presented FIRST?

- A. Every finding
- B. Assessment labor hours
- C. A request to fund every control
- D. Material scenarios, appetite, assumptions, and treatments

Question 16 (CISM5-043)

Which action BEST represents risk transfer or sharing?

- A. Purchasing insurance for specified financial losses
- B. Implementing a preventive control
- C. Stopping the activity
- D. Formally retaining exposure

Question 17 (CISM5-044)

What is the PRIMARY responsibility of a control owner?

- A. Set enterprise appetite
- B. Accept every related business risk
- C. Operate the control and report performance
- D. Replace internal audit

Question 18 (CISM5-045)

Scenario: A library considers an optional feature allowing anonymous executable uploads. Value is minimal, safeguards cost more than the benefit, and untreated risk is far above appetite.

Which response is MOST appropriate?

- A. Remove executable uploads from the feature
- B. Accept because the feature is optional
- C. Transfer accountability to users
- D. Launch and reassess after attacks

Question 19 (CISM5-046)

Scenario: A records platform violates a binding security requirement. The owner wants to accept the risk for six months to avoid delaying launch.

What is the BEST action?

- A. Record acceptance and launch
- B. Implement compliant treatment or change the launch
- C. Buy insurance instead
- D. Let the control operator decide

Question 20 (CISM5-047)

Scenario: Two controls reduce payment-fraud risk within tolerance. Control X costs twice as much and delays customers; Control Y meets obligations without material delay.

Which should be recommended?

- A. Control X because price proves strength
- B. Neither because risk remains
- C. Both controls regardless of benefit
- D. Control Y because it achieves acceptable risk with lower cost and impact

Question 21 (CISM5-048)

Scenario: A factory application was accepted for isolated use. A change adds internet access and remote vendor administration but is labeled routine.

What should happen before approval?

- A. Reassess connectivity, threat access, controls, and third-party dependency
- B. Let the vendor accept risk
- C. Approve because the application is unchanged
- D. Use the old acceptance

Question 22 (CISM5-049)

Scenario: A treatment plan requires reassessment after three weeks above a fraud threshold. The third breach occurs while annual loss remains within budget.

Why should reassessment begin?

- A. A threshold breach proves total control failure
- B. The trigger signals changing exposure before annual totals obscure the trend
- C. Budget status is formal acceptance
- D. Monitoring transfers ownership

Question 23 (CISM5-050)

Scenario: A consulting firm discovers after signature that a supplier stores client files with an unreviewed subcontractor. Security review occurs during implementation.

Which process change is MOST effective?

- A. Review every supplier after launch
- B. Ban all external services
- C. Require risk-tiered data-flow and subcontractor review before selection and contracting
- D. Let procurement accept every risk

Question 24 (CISM5-051)

Scenario: A clinic cannot install standard software on a certified imaging device. Proposed isolation is tested, but an undocumented wireless maintenance path bypasses it.

What should the information security manager conclude?

- A. Isolation is effective because it exists
- B. Control coverage and residual risk require reassessment before authorized approval
- C. Risk transfers to the device vendor
- D. The exception should be permanent

Question 25 (CISM5-052)

Scenario: A six-month acceptance permits mobile access only in read-only mode. A change would enable editing before the acceptance expires.

What should occur FIRST?

- A. Approve because time remains
- B. Reassess and obtain a new decision from the authorized owner
- C. Transfer acceptance to the supplier
- D. Enable editing and monitor later

Question 26 (CISM5-053)

Scenario: Privileged-access reviews have declined for four quarters, breached the approved threshold, and left risk above tolerance. Corrective milestones were missed twice.

What is the MOST appropriate action?

- A. Wait for annual review
- B. Lower the threshold
- C. Escalate the exposure and missed actions for owner review
- D. Transfer ownership to reviewers

Question 27 (CISM5-054)

Scenario: Due diligence assumed an acquired platform would remain isolated for a year. Management now wants immediate connection to customer identity and billing systems.

What is the MOST appropriate action?

- A. Use the due-diligence rating
- B. Connect and watch for incidents
- C. Reassess trust, data flows, controls, and aggregate impact before connection
- D. Ask the seller to accept risk

Question 28 (CISM5-055)

Scenario: Six units hold valid local exceptions to encryption. Together they cover most customer records and exceed enterprise appetite.

What should the information security manager recommend?

- A. Keep only local reporting
- B. Split records into smaller groups
- C. Delete every exception
- D. Report aggregate exposure while retaining local records

Question 29 (CISM5-056)

Scenario: A marketplace must reduce seller-fraud risk before a holiday peak. One control reaches tolerance in two weeks with minor friction; a more convenient control will take five months. Costs are similar.

Which response is BEST?

- A. Accept informally
- B. Wait five months
- C. Deploy before the peak
- D. Deploy neither

Question 30 (CISM5-057)

Scenario: Executives receive vulnerability totals but cannot see whether identity risk is improving or what funding decision is required.

Which reporting approach is MOST appropriate?

- A. Material risk, treatment, exceptions, and decisions
- B. Add all raw findings
- C. Report only spending
- D. Wait until treatment ends

Answer Key

Domain II - Information Security Risk Management

1 D	2 B	3 A	4 C	5 D
6 A	7 C	8 D	9 B	10 B
11 A	12 B	13 D	14 A	15 D
16 A	17 C	18 A	19 B	20 D
21 A	22 B	23 C	24 B	25 B
26 C	27 C	28 D	29 C	30 A

Detailed Explanations

Question 1 (CISM5-028)

Correct answer: D - The exposure before considering the effect of controls

Inherent risk is assessed before controls are considered. Accepted risk is a decision, target risk is the intended post-treatment state, and residual risk reflects current controls.

Question 2 (CISM5-029)

Correct answer: B - To define acceptable variation or limits for a particular objective or exposure

Risk tolerance translates broader appetite into practical limits for a specific objective or exposure. It does not require financial calculation, define total capacity, or assign control ownership.

Question 3 (CISM5-030)

Correct answer: A - Reassess the deadline scenario using the 20-minute tolerance and related business impact

The deadline changes the business objective and acceptable disruption, so the relevant scenario must use the tighter approved tolerance. A uniform technical target or waiting for loss would misstate current exposure.

Question 4 (CISM5-031)

Correct answer: C - Availability criticality should reflect inventory-loss and detection dependencies

Criticality must reflect the gateway's role in detecting conditions that threaten inventory. Low confidentiality does not imply low availability impact, hardware-only review omits the service, and criticality still depends on context.

Question 5 (CISM5-032)

Correct answer: D - Customer-side controls may be unowned and ineffective

Misunderstood shared responsibility can leave access and retention controls unassigned. Cloud use is not automatically riskier, accountability remains with the firm, and provider assurance does not validate customer configuration.

Question 6 (CISM5-033)

Correct answer: A - Safety, malicious-command, lifecycle, and supplier-dependency scenarios were omitted

Autonomous operations require assessment of command abuse, physical consequences, update lifecycle, and provider dependency. Price and appearance are not the core security gap, and productivity evidence does not address exposure.

Question 7 (CISM5-034)

Correct answer: C - When expert judgment must support initial prioritization and reliable numerical data is limited

Defined qualitative criteria support consistent prioritization when numerical evidence is limited. They do not provide exact financial forecasts, convert severity directly to currency, or remove business impact from analysis.

Question 8 (CISM5-035)

Correct answer: D - \$45,000

Single loss expectancy is \$900,000 multiplied by 20%, or \$180,000. Multiplying by 0.25 produces an annualized loss expectancy of \$45,000; the other values omit or misapply a factor.

Question 9 (CISM5-036)

Correct answer: B - An incomplete control design

The procedure is designed with an incomplete population, so correct execution cannot address all privileged activity. Timely performance is not an operating failure, and the omission is neither a realized loss nor a threat event.

Question 10 (CISM5-037)

Correct answer: B - Report current residual risk and record the verified target separately

Residual risk reflects controls operating now; the planned state is target risk and depends on verified implementation. Funding does not create current effectiveness, alter inherent exposure, or justify hiding the scenario.

Question 11 (CISM5-038)

Correct answer: A - A shared fourth-party failure could disrupt all three services simultaneously

The common rendering service creates correlated concentration risk. Design differences do not drive the exposure, ratings still depend on context, and outsourcing never removes the banks' accountability.

Question 12 (CISM5-039)

Correct answer: B - The donation service because its campaign impact is imminent

Timing and direct impact on a current objective make the donation scenario more urgent. Asset age and finding counts do not determine business priority, and equal scores can conceal meaningful context.

Question 13 (CISM5-040)

Correct answer: D - A range or distribution with assumptions and sensitivity information

A range with assumptions and sensitivity transparently represents the evidence and model limits. A maximum is not an expected value, technical scores do not directly equal financial loss, and limited data can still inform decisions.

Question 14 (CISM5-041)

Correct answer: A - Residual risk may be understated by irrelevant control evidence

Control evidence must cover the asset and scenario being assessed. Frequent but irrelevant tests do not prove database recovery, do not change inherent risk, and cannot support automatic acceptance.

Question 15 (CISM5-042)

Correct answer: D - Material scenarios, appetite, assumptions, and treatments

The board needs business consequences, appetite comparison, assumptions, and treatment choices. Technical volume and effort do not establish materiality, and funding all controls ignores proportionality.

Question 16 (CISM5-043)

Correct answer: A - Purchasing insurance for specified financial losses

Insurance can transfer or share defined financial consequences. Stopping is avoidance, a preventive control is mitigation, and retaining exposure is acceptance.

Question 17 (CISM5-044)

Correct answer: C - Operate the control and report performance

The control owner is accountable for operation and evidence of the assigned control. This role does not confer enterprise appetite authority, automatic risk ownership, or audit independence.

Question 18 (CISM5-045)

Correct answer: A - Remove executable uploads from the feature

Removing the optional capability avoids a high exposure with little business value. Optional status does not justify acceptance, user terms cannot transfer accountability, and launching first is not a sound response.

Question 19 (CISM5-046)

Correct answer: B - Implement compliant treatment or change the launch

A binding duty cannot be waived through ordinary business acceptance. Legal and authorized leadership must secure compliance or change the launch; insurance and control operation do not remove the obligation.

Question 20 (CISM5-047)

Correct answer: D - Control Y because it achieves acceptable risk with lower cost and impact

Control Y meets risk and obligation criteria with better cost and customer outcomes. Higher cost does not prove value, both controls are not justified, and acceptable residual risk need not be zero.

Question 21 (CISM5-048)

Correct answer: A - Reassess connectivity, threat access, controls, and third-party dependency

Internet and vendor access invalidate core assumptions of the prior assessment. The same application can have different exposure, and the vendor cannot accept the factory's business risk.

Question 22 (CISM5-049)

Correct answer: B - The trigger signals changing exposure before annual totals obscure the trend

The trigger is a leading signal requiring review despite the annual total. It does not prove complete failure, equal acceptance, or transfer ownership to monitoring staff.

Question 23 (CISM5-050)

Correct answer: C - Require risk-tiered data-flow and subcontractor review before selection and contracting

Early, risk-tiered review preserves options to select, negotiate, treat, or obtain authorized acceptance. Later review loses leverage, a universal ban is disproportionate, and procurement lacks automatic authority for all risks.

Question 24 (CISM5-051)

Correct answer: B - Control coverage and residual risk require reassessment before authorized approval

The bypass undermines the proposed control, so effectiveness and residual risk must be reassessed. Control presence is insufficient, certification does not justify permanence, and vendor involvement does not transfer accountability.

Question 25 (CISM5-052)

Correct answer: B - Reassess and obtain a new decision from the authorized owner

Editing violates a material acceptance assumption, requiring reassessment and a new authorized decision. Calendar validity does not preserve changed conditions, and neither supplier transfer nor postchange monitoring is sufficient.

Question 26 (CISM5-053)

Correct answer: C - Escalate the exposure and missed actions for owner review

Persistent deterioration and missed actions justify escalation to the accountable owner. Lowering targets or waiting hides exposure, and control staff do not inherit business-risk ownership.

Question 27 (CISM5-054)

Correct answer: C - Reassess trust, data flows, controls, and aggregate impact before connection

Immediate integration invalidates the isolation assumption and creates new trust and impact paths. The old rating no longer fits, monitoring after connection is late, and the seller cannot own the buyer's risk.

Question 28 (CISM5-055)

Correct answer: D - Report aggregate exposure while retaining local records

Authorized local exceptions can create unacceptable aggregate exposure requiring enterprise authority. Local records remain useful; deletion or artificial splitting would conceal rather than manage risk.

Question 29 (CISM5-056)

Correct answer: C - Deploy before the peak

The timely control addresses the peak exposure within tolerance while allowing later improvement. Waiting or informal acceptance leaves above-tolerance risk, and manageable friction does not justify rejecting treatment.

Question 30 (CISM5-057)

Correct answer: A - Material risk, treatment, exceptions, and decisions

Executive reporting must connect exposure to appetite, show treatment results and exceptions, and identify decisions. Raw findings and spending lack outcome context, while delayed reporting prevents timely action.